

Enterprise AI Architect Learning Path v3 – Phase Guide 8

Enterprise AI Architect Learning Path v3 – Phase Guide 8

Security, Governance & Portfolio Completion

Purpose of This Phase

The previous phases focused on building increasingly sophisticated systems:

- Production RAG architectures
- Agent orchestration platforms
- MCP tool ecosystems
- Multi-agent workflows
- Operational telemetry and LLMOps

At this point, you have built systems that can operate.

Phase 8 focuses on the final responsibility of an Enterprise AI Architect:

Ensuring systems are secure, governed, explainable, and suitable for enterprise adoption.

This phase is not about adding more features.

It is about demonstrating professional architectural maturity.

By the end of this phase, the question should no longer be:

"Can this AI system work?"

Instead it should be:

"Can an organization trust, operate, govern, and scale this AI system?"

Why This Phase Matters

Many AI projects fail after the prototype stage because organizations cannot answer critical questions such as:

- How do we manage risk?
- What happens during failures?
- How do we prevent misuse?
- How do we ensure transparency?

- How do we govern agent behavior?
- Who is accountable for AI decisions?
- How do we demonstrate compliance?

Enterprise AI Architectures succeed when they combine:

- Technical capability
 - Security
 - Governance
 - Accountability
 - Operational maturity
-

Phase Objectives

Upon completion of this phase, you should be able to:

- Perform AI-focused threat modeling
 - Apply OWASP LLM guidance
 - Apply NIST AI RMF principles
 - Design governance frameworks
 - Create risk registers
 - Document security controls
 - Produce executive-facing architectural artifacts
 - Present AI systems professionally
 - Evaluate AI risks
 - Assemble a complete enterprise architecture portfolio
-

Architect Mindset

One of the most important lessons of this phase is:

Enterprise AI Architecture is ultimately a governance discipline.

Technology matters.

Models matter.

Agents matter.

But organizations place trust in:

- Policies
- Controls
- Accountability
- Risk management

The architect's responsibility extends beyond implementation.

Primary Resources

Required

R14

OWASP Top 10 for LLM Applications

Focus Areas:

- Prompt Injection
 - Tool Abuse
 - Excessive Agency
 - Sensitive Data Disclosure
 - Supply Chain Risks
-

R15

NIST AI Risk Management Framework

Focus Areas:

- Govern
 - Map
 - Measure
 - Manage
-

R16

OpenTelemetry Documentation

Focus Areas:

- Evidence generation
 - Auditable operations
 - Visibility
-

R1

AI Engineering

Focus Areas:

- Evaluation
- Safety

- Operational excellence
-

R2

Designing Machine Learning Systems

Focus Areas:

- Risk
 - Operations
 - Reliability
 - Monitoring
-

Core Technical Skills

1. Threat Modeling

Every AI system should undergo threat analysis.

For each portfolio project identify:

Assets

Examples:

- Knowledge repositories
 - Workflow state
 - User inputs
 - Agent tools
-

Threats

Examples:

- Prompt injection
 - Data leakage
 - Unauthorized access
 - Tool misuse
-

Controls

Examples:

- Validation

- Approvals
 - Permissions
 - Monitoring
-

2. OWASP for LLM Applications

Learn how major AI risks apply to your architectures.

Examples:

Prompt Injection

Can a user manipulate behavior?

Sensitive Data Disclosure

Can protected information leak?

Excessive Agency

Can agents perform actions beyond their authority?

Tool Misuse

Can external capabilities be abused?

Supply Chain Risks

Can compromised tools introduce vulnerabilities?

3. NIST AI RMF

The NIST framework becomes the primary governance structure for the portfolio.

Govern

Who owns decisions?

Who manages risk?

What policies exist?

Map

Where does AI influence outcomes?

Who is affected?

What assumptions exist?

Measure

How is system quality evaluated?

How are risks monitored?

Manage

How are issues addressed?

How are safeguards maintained?

4. Risk Management

Create formal risk documentation.

Examples:

	☰ Risk	☰ Impact	☰ Likelihood	☰ Mitigation
1	Prompt Injection	High	Medium	Input Validation
2	Data Exposure	High	Low	Access Controls
3	Poor Retrieval	Medium	Medium	Evaluation Suite
4	Tool Abuse	High	Medium	Approval Gates

Architects should demonstrate objective assessment rather than speculation.

5. Governance Documentation

The goal is repeatability.

Policies should define:

- Human involvement

- Approval requirements
 - Evaluation standards
 - Operational responsibilities
 - Escalation paths
-

6. Executive Communication

Architects must communicate beyond technical audiences.

Produce artifacts understandable by:

- Engineering leaders
 - Product managers
 - Security teams
 - Governance groups
 - Executive stakeholders
-

Security Review by Project

RPG Catalog RAG

Security Focus

Evaluate:

- Data exposure
 - Citation integrity
 - Retrieval abuse
-

Governance Focus

Define:

- Source authority
 - Content ownership
 - Quality standards
-

Virtual GM

Security Focus

Evaluate:

- State corruption
 - Unauthorized changes
 - Prompt manipulation
-

Governance Focus

Define:

- Human approval requirements
 - Decision accountability
 - Workflow controls
-

AI Publishing Company

Security Focus

Evaluate:

- Unapproved publishing
 - Workflow misuse
 - Content integrity
-

Governance Focus

Define:

- Human ownership
 - Approval authority
 - Publication standards
-

MCP Tool Ecosystem

Security Focus

Evaluate:

- Tool permissions
- Privilege escalation
- Tool abuse

Governance Focus

Define:

- Tool ownership
 - Access controls
 - Audit requirements
-

Phase Project

Enterprise Architecture Portfolio

This is the final capstone deliverable.

The portfolio demonstrates architect-level competency across all program phases.

Required Portfolio Components

Architecture Diagrams

Create:

Context Diagram

System boundaries.

Container Diagram

Major services.

Component Diagram

Internal structures.

Sequence Diagram

Workflow interactions.

Architecture Decision Records

Include all ADRs produced throughout the program.

Target:

ADR-001 through ADR-021

as applicable.

Risk Register

Document:

- Risks
 - Mitigations
 - Residual risks
 - Ownership
-

Governance Checklist

Document:

- Policies
 - Controls
 - Review processes
 - Approval requirements
-

Evaluation Reports

Include:

- Retrieval evaluations
 - Workflow evaluations
 - Quality assessments
-

Deployment Architecture

Document:

- Hosting options

- Operational considerations
 - Observability design
-

Portfolio Readme

A professional summary describing:

- Projects
 - Objectives
 - Architecture
 - Lessons learned
-

Architecture Deliverables

ADR-022

Enterprise Security Strategy

Document:

- Security principles
 - Risk priorities
 - Protection strategy
-

ADR-023

Governance Framework

Document:

- Governance model
 - Human responsibilities
 - Escalation paths
-

ADR-024

Portfolio Architecture Summary

Document:

- Architectural evolution
 - Key decisions
 - Lessons learned
-

Suggested Sprint Progression

Sprint 1 — Threat Modeling

Goals:

- Review all systems
- Identify threats

Done When:

- Threat models completed
-

Sprint 2 — OWASP Review

Goals:

- Map OWASP risks
- Identify mitigations

Done When:

- Security review completed
-

Sprint 3 — NIST AI RMF Review

Goals:

- Apply governance framework

Done When:

- RMF documentation exists
-

Sprint 4 — Risk Register

Goals:

- Identify risks
- Define mitigations

Done When:

- Risk register complete
-

Sprint 5 — Portfolio Assembly

Goals:

- Collect architecture artifacts

Done When:

- Portfolio package assembled
-

Sprint 6 — Executive Presentation

Goals:

- Create portfolio narrative

Done When:

- Presentation materials complete
-

Sprint 7 — Final Review

Goals:

- Assess readiness
- Close gaps

Done When:

- Graduation criteria met
-

Common Pitfalls

Pitfall 1

Treating Security as a Final Checklist

Security should reflect architectural decisions made throughout the program.

Pitfall 2

Confusing Governance with Compliance

Governance is the ongoing management of a system.

Compliance may be one outcome.

Pitfall 3

Ignoring Human Accountability

Responsible AI systems always maintain clear ownership.

Pitfall 4

Documenting Controls Without Evidence

Controls should be supported by:

- Tests
- Logs
- Evaluations
- Architecture decisions

Pitfall 5

Presenting Features Instead of Architecture

Portfolio reviews should emphasize:

- Decisions
- Tradeoffs
- Risks
- Governance

rather than feature counts.

Enterprise Translation Layer

The final portfolio should demonstrate transferable enterprise patterns.

	≡ Portfolio Project	≡ Enterprise Equivalent
1	RPG Catalog RAG	Knowledge Management Platform
2	Virtual GM	Workflow Automation Platform
3	Publishing Company	Multi-Agent Business Process System
4	MCP Server	Enterprise Integration Layer
5	Evaluation Suite	AI Quality Assurance Program
6	Governance Package	Enterprise AI Governance Framework

The domain is tabletop gaming and publishing.

The architecture is enterprise-grade.

Definition of Done

Phase 8 is complete when:

- Threat models exist for all portfolio systems
 - OWASP review is documented
 - NIST AI RMF review is documented
 - Risk register is completed
 - Governance checklist is completed
 - Architecture diagrams are complete
 - Deployment architecture is documented
 - Portfolio package is assembled
 - ADRs are finalized
 - Executive-ready presentation materials exist
-

Graduation Assessment

You are ready to consider the learning path complete when you can confidently answer:

- Can I design enterprise-grade AI architectures?
- Can I explain and defend architectural decisions?
- Can I design and govern agent systems?
- Can I evaluate AI quality objectively?
- Can I secure AI systems and tool ecosystems?
- Can I operate AI systems in production?
- Can I communicate risks and governance requirements?
- Can I present a complete professional AI architecture portfolio?

If all answers are "yes," then you have successfully completed the **Enterprise AI Architect Learning Path v3** and produced an **Enterprise Agentic AI Architect Portfolio**.